ida 2030 – Technical Documentation

SPARK – Alice Hristov, Sudenur Yildiz, Tushna Kapoor, Fathy Shalaby

ida 2030 turns ida from an information chatbot into a secure digital government agent – all public services in one app. ida reads letters, speaks the resident's language, fetches register data via Project X (dadeX) with consent so nobody has to provide the same data twice, alerts residents to deadlines and possible entitlements, and submits applications after their confirmation. Residents use ida by chat or by voice with the phone agent; every login uses ID Austria and critical actions add a face match. This document describes the architecture, requirements, security and AI design behind it.

1. At a glance

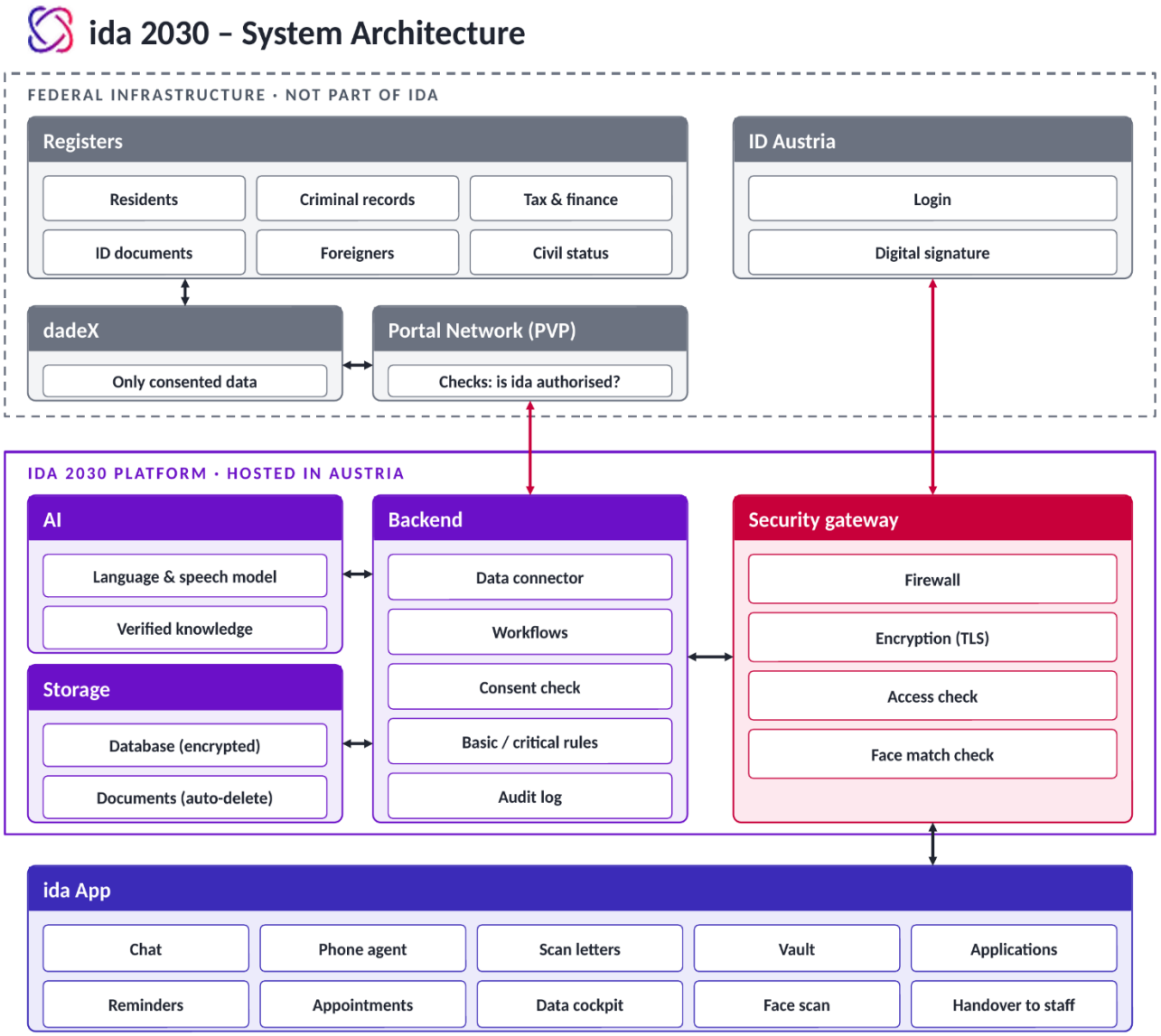
Purpose	Next stage of ida: from answering questions to completing public services with the resident
Users	Residents, relatives with power of attorney, service-point staff, civil servants
Channels	App (iOS / Android) with chat and phone agent, web, Digital Austria service points
Core capabilities	Multilingual chat · phone agent (voice call with ida in the app) · letter scanning · vault with register data · pre-filled applications · submission · reminders · appointments · data cockpit
Identity	ID Austria for every login; face match added for critical actions
Data access	Registers via dadeX and the Portal Network (PVP), consent-scoped, never copied
AI	Language model hosted in Austria, grounded in a verified knowledge base; humans confirm, authorities decide
Security model	CIA triad applied to every layer; two security levels (basic / critical)
Requirements	39 functional · 30 non-functional
Prototype	One procedure end to end: renewing a residence permit; register access simulated with test data

Five things to know

- **Once-Only:** data comes from the registers via Project X (dadeX), with consent – residents never upload what the state already has.
- **Security matches the stakes:** ID Austria for every login, face match only for critical actions; no face scan possible? Verify once in person at a service point.
- **The AI never invents or decides:** answers come from a verified knowledge base; residents confirm, authorities decide.
- **One app for everyone:** chat and phone agent, six languages, Easy Language, WCAG 2.2 AA as target.
- **Honest prototype:** one procedure end to end; ID Austria, face match and registers are simulated.

2. System architecture

Data stays in the registers: ida reaches them only through the Portal Network as an authorised service, with the resident's consent. The dashed frame is existing federal infrastructure under Project X and not part of ida. The phone agent is a feature of the app: same login, backend, knowledge base and rules – only input and output change from text to voice. Each component is described in Appendix A.



Design principles: no new data silo (query, never copy) · facts from verified sources, not from the model · every component replaceable without changing the others · a new procedure is a new workflow template, not new code.

3. Functional requirements

39 requirements in 12 areas – here in short, the full list with priorities is in Appendix B. Level: – no login · B basic (ID Austria) · K critical (ID Austria + face match).

Area	Key requirements	Level
Access	Questions without login; ID Austria login; face match before critical actions (or one visit to a service point); consent per data area	– / B / K
Vault	Fetch documents from registers with consent; upload missing ones; show origin and expiry	B
Guide	Understands everyday language and many languages; explains photographed letters; plain and Easy Language; German terms on tap; source in every answer	– / B
Applications	Guided workflow; pre-filled form showing where each value came from; uncertain values confirmed; submit only after confirmation, withdraw within 24 h	B / K
Reminders & entitlements	Reminders before deadlines and expiry; hints on possible entitlements – never decisions	B
Appointments & status	Book appointments with checklist; status in stages; answer authority requests in the app	B
Power of attorney	Limited, time-bound power of attorney for relatives	K
Data cockpit	Every register query, entitlement check and submission with purpose, time and authority; revoke consent; PDF download	B
Human help	Handover to staff with case summary – on request or automatically when ida is unsure	– / B
Accessibility	At least six languages, read aloud and voice input, large text and high contrast, sign language videos	–
Phone agent	Voice call in the app; AI disclosed; key values read back; face match on screen for critical actions; live transfer to staff	– / B / K

4. Non-functional requirements

30 requirements – here in short, the full list with measurable targets is in Appendix C. Targets for performance and availability are assumptions for the pilot.

Quality	Key requirement	Target / evidence
Security	Strong login; register access only server-side; encryption in transit and at rest; pen tests before each release	TLS 1.3, AES-256, test reports
Privacy	Consent per purpose; no register copies; biometrics on device only; hosting in Austria / EU; no training on inputs	DPIA, deletion concept
AI reliability	Facts only from the verified knowledge base; German text binding; when unsure ask back or hand over	Test cases per procedure and language
Accessibility	WCAG 2.1 AA mandatory, 2.2 AA target; touch targets ≥ 44 px; text scalable to 200 %	Audit report
Usability	Federal corporate design; plain language B1; a typical application in under 10 minutes	User tests, pilot
Performance	Chat answer < 3 s; letter explanation < 10 s; voice response < 1.5 s	Monitoring
Availability	99.9 % uptime, 24/7; fallback to chat or human hotline	Monitoring, failover test
Scalability	New procedure = workflow template, new language = glossary + tests – no new code	Effort per procedure

5. Security

Security is designed along the CIA triad: every layer has a measure for confidentiality, integrity and availability, and the level of protection rises with what is at stake.

5.1 CIA triad by layer

Layer	Confidentiality	Integrity	Availability
App	On-device face scan, no face data leaves the phone; secure storage; certificate pinning	Signed app builds; signed liveness result	Offline view of vault and reminders
Security gateway	TLS 1.3; access check per request	WAF blocks tampered requests; request signing	DDoS protection, rate limits, load balancing
Backend	Least privilege; consent check before every query; role-based access	Input validation; immutable audit log; confirmation before submission	Redundant instances; queue for reminders
AI	No training on inputs; prompt-injection filter on documents	Facts only from verified knowledge base; output checked against it	Model replaceable; fallback to human handover
Storage	AES-256 at rest; keys in a hardware security module; automatic deletion	Checksums; versioned records	Daily encrypted backups, RPO 1 h, RTO 4 h (pilot target)
Federal link	Portal Network authentication; only consented fields from dadeX	Data comes signed from authoritative registers	Retry and status messages if a register is unavailable
Phone agent	Asks before reading sensitive data aloud and offers to show it on screen; no recording without consent	Read-back of key values; security rules enforced in the backend, not by the AI	Fallback to chat or human hotline

5.2 Security levels

Level	Identity check	Actions
Public	None	Ask general questions, explain procedures
Basic	ID Austria login	Vault, letters, reminders, appointments, status
Critical	ID Austria + face match with liveness check	Submit applications, grant power of attorney, access sensitive data (e.g. criminal record), change personal data, first login on a new device

Anyone who cannot use face match verifies once at a Digital Austria service point, so nobody is excluded. The same levels apply during a phone call: a critical action pauses the call for a face match on screen.

5.3 Threat model (STRIDE)

Threat	Example	Countermeasure
Spoofing	Someone logs in as another person	ID Austria + face match with liveness check
Tampering	Manipulated application data	Confirmation step, signed requests, immutable log
Repudiation	"I never submitted that"	Audit log with ID Austria confirmation
Information disclosure	Data leak from storage	No register copies, encryption, least privilege
Denial of service	Overload before a deadline	DDoS protection, rate limits, auto-scaling
Elevation of privilege	Prompt injection in an uploaded letter	Documents treated as data only; AI cannot trigger actions on its own

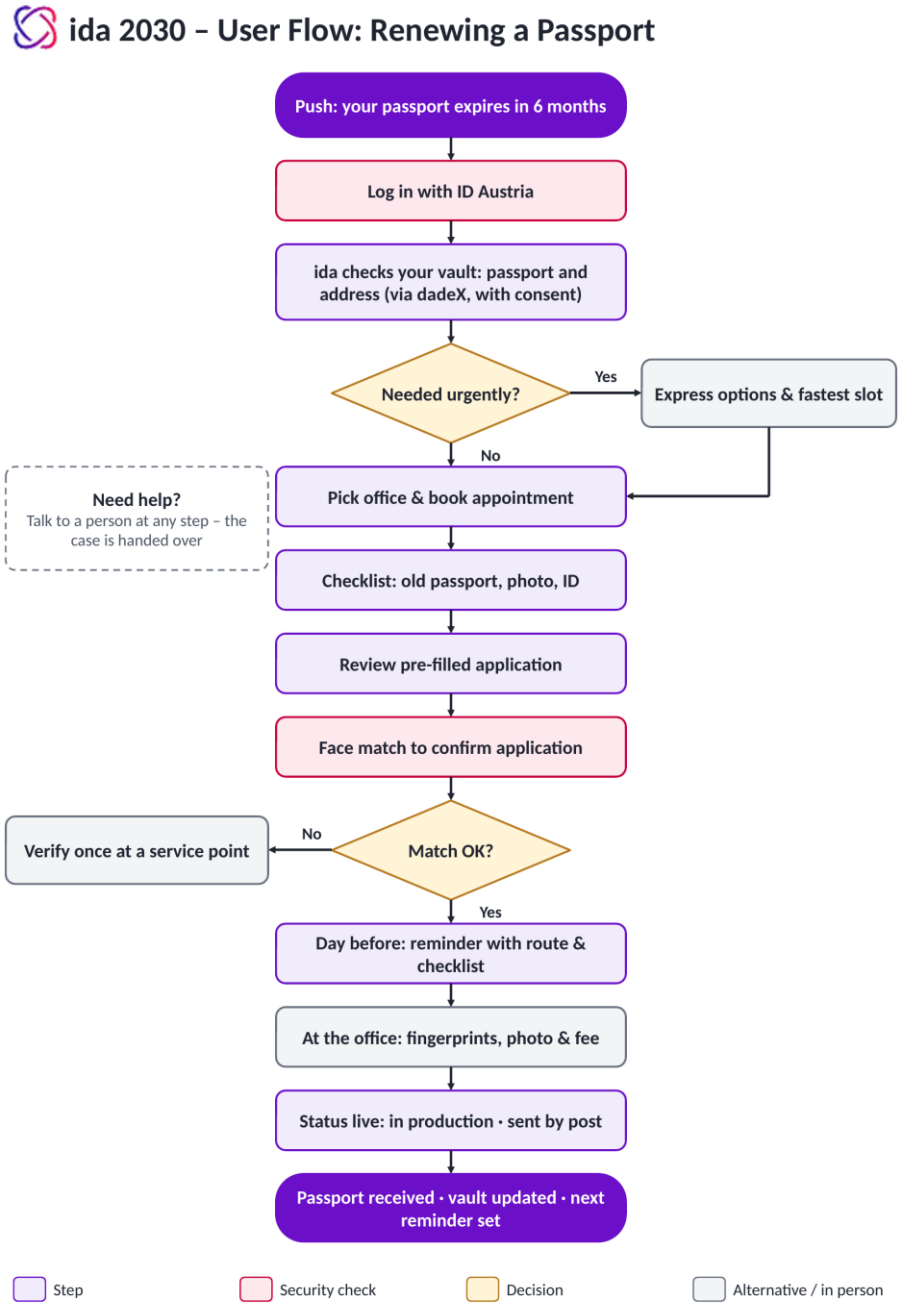
Threats specific to the phone agent are listed in Appendix D.

6. User flow and data flow

6.1 Example: renewing a passport

A reminder six months before expiry starts the process. ida checks the passport and address via dadeX, books the appointment and pre-fills the application.

Confirming the application is a critical action and therefore requires a face match; anyone without a match verifies once at a service point. Fingerprints, the photo and the fee are handled in person at the passport office. A person can take over at any step.



6.2 Data flow of a critical action

What happens behind the screen, using the example of renewing a residence permit. Only steps 4 and 5 cross into federal infrastructure, and only with consent.

The general user flow and the phone agent flow are in Appendix E and F.

1. **Login** – the resident logs in with ID Austria; the security gateway receives a signed token.
2. **Face match** – the app performs a liveness scan and compares it with the passport chip photo on the device; the backend receives only a signed pass / fail.
3. **Consent** – the resident approves this one purpose; the consent check issues a token limited to the needed data fields.
4. **Secure request** – the data connector authenticates via the Portal Network as an authorised service.
5. **Data fetch** – dadeX returns only the consented fields from the registers (e.g. passport validity, registered address, current permit).
6. **Prepare** – the AI explains the procedure in the resident's language and pre-fills the form; facts are checked against the verified knowledge base; uncertain values are flagged.
7. **Confirm and submit** – the resident reviews and confirms; the backend submits to the authority, books the biometrics appointment and writes every step to the audit log visible in the data cockpit.

Same flow by voice: in the app the resident can also call ida. The call uses the same backend and rules; for step 2 ida pauses the call and asks for the face match on screen, and before step 7 it reads back the key values so the resident can confirm them.

7. AI design and quality assurance

The model explains and pre-fills; it never decides and never invents facts.

Principle	How it works
Grounding	Answers come from a verified knowledge base (service descriptions, legal glossary); every answer cites its source
German core, many languages	Processing and checks in German; translation is the last step, with fixed glossary terms and the German original one tap away
Safety checks	Deadlines, fees and requirements are checked against the knowledge base; uploaded letters are data only and cannot trigger actions
Human in the loop	Every submission needs the resident's confirmation; entitlement hints are never decisions; unsure, hardship or complaint → staff

Principle	How it works
Voice	Speech-to-text → same AI as the chat → text-to-speech, hosted in Austria; short spoken answers; key values read back
Transparency & evaluation	Every AI answer is labelled; test set per procedure and language; native-speaker review before a language goes live

8. Compliance

Each legal requirement maps to a concrete design decision. (Concept-level assessment, not legal advice.)

Framework	Requirement	How ida 2030 meets it
GDPR	Lawful basis, purpose limitation, data minimisation; biometrics are special-category data (Art. 9)	Consent per purpose; only needed fields; face data processed on device and never stored; data protection impact assessment before launch; no voice recording by default
EU AI Act	Transparency; high-risk rules where AI affects access to public benefits (applicable from 2 Dec 2027)	AI labelled; ida only gives hints on entitlements, authorities decide; 1:1 identity verification is not high-risk biometric identification; the phone agent says it is an AI (Art. 50)
AVG amendment (planned)	Submissions via chatbot	Submission only after explicit confirmation with ID Austria
Project X / dadeX	Register access needs a legal basis per data consumer	ida to be designated as authorised data consumer by ordinance
Web Accessibility Act (WZG)	Public bodies must meet WCAG 2.1 AA	WCAG 2.1 AA mandatory, 2.2 AA target
Corporate Design of the Federal Government	Shared visual identity	Federal colours and Source Sans Pro for digital media
Standards	Information security, AI and quality management	ISO/IEC 27001, ISO/IEC 42001, ISO 9001 in the pre-launch phase

9. Operations, testing and prototype scope

9.1 Operations and testing

Operations: Hosted in a government data centre in Austria, containerised and scaled automatically; 24/7 security monitoring; daily encrypted backups (recovery point 1 h, recovery time 4 h – pilot targets); staged releases.

Testing: unit and integration tests, penetration tests, AI evaluation, accessibility audit, load tests, voice tests with dialects, and user tests with older people, non-German speakers and people with disabilities – all must pass before each release.

9.2 Prototype scope (hackathon)

Part	Status
App screens and user journey	Built (clickable mockup)
Letter explanation and multilingual answers	Working with a real language model
Knowledge base for one procedure	Working (residence permit)
ID Austria login and face match	Simulated
Register access via Portal Network and dadeX	Simulated with test data
Submission to the authority	Simulated
Phone agent	Concept; demo call with test data

Appendix

Details for readers who want to go deeper. The main part above covers every topic.

A. Architecture components

Layer	Component	Responsibility
Client	ida App (iOS / Android), web	Chat, phone agent (voice call with ida), letter scanning, vault, applications, reminders, appointments, data cockpit, on-device face scan
Security	Security gateway	Firewall, TLS encryption, access check, face match verification (pass / fail only)
Core	Backend	Workflows per procedure, consent check, basic / critical rules, audit log, data connector
Core	AI	Language and speech model hosted in Austria; verified knowledge base (service descriptions, legal glossary)
Core	Storage	Encrypted database; document storage with automatic deletion
Federal (external)	ID Austria	Login and digital signature
Federal (external)	Portal Network (PVP)	Authenticates ida as an authorised authority service
Federal (external)	dadeX	Data hub; releases only consented fields from the registers
Federal (external)	Registers	Residents, ID documents, foreigners, civil status, criminal records, tax and further registers under Project X

B. Functional requirements (full list)

Priority: M must · S should · C could. Level: – no login · B basic · K critical.

ID	Area	Requirement	Prio	Level
F01	Access	Ask general questions without login; answers with sources	M	–
F02	Access	Log in with ID Austria for all personal functions	M	B
F03	Access	Face match with liveness check before critical actions; no face scan possible? Verify once in person at a service point	M	K
F04	Access	Grant, change and revoke consent per data area	M	B
F05	Vault	Fetch documents and data from registers via dadeX with consent	M	B
F06	Vault	Upload missing documents as photo or PDF	M	B
F07	Vault	Show origin (verified by the state / uploaded) and expiry dates	M	B
F08	Guide	Understand colloquial input, typos and multiple languages	M	–
F09	Guide	Read photographed letters: what, by when, what to do	M	B
F10	Guide	Answer in plain language (B1), Easy Language (A2) on request	M	–
F11	Guide	Show German legal terms and the German original on one tap	M	–
F12	Guide	Cite a source in every answer; ask back when information is missing	M	–
F13	Applications	Guided workflow per procedure with checklist against the vault	M	B
F14	Applications	Pre-fill the official form and show where each value came from	M	B
F15	Applications	Flag uncertain values for active confirmation	M	B
F16	Applications	Submit only after confirmation; withdraw within 24 h	M	K

ID	Area	Requirement	Prio	Level
F17	Applications	Standing authorisation for routine applications, revocable	C	K
F18	Reminders	Remind before documents and deadlines expire	M	B
F19	Reminders	Hint at possible entitlements with reason, never decide	S	B
F20	Appointments	Find and book appointments; checklist of what to bring	S	B
F21	Appointments	Reminder on the day before	C	B
F22	Status	Show application status in stages	M	B
F23	Status	Explain authority follow-up requests and answer in the app	S	B
F24	Power of attorney	Grant power of attorney to relatives with limited rights and expiry	S	K
F25	Power of attorney	Create written power of attorney where an authority requires it	C	K
F26	Data cockpit	List every register query, entitlement check and submission with purpose, time and authority; revoke consent from here	M	B
F27	Data cockpit	Download the log as PDF	C	B
F28	Human help	Hand over to staff with a case summary (call-back, chat, service point)	M	B
F29	Human help	Automatic handover on uncertainty, hardship cases and complaints	M	–
F30	Accessibility	At least six languages	M	–
F31	Accessibility	Read aloud and voice input	M	–
F32	Accessibility	Videos in Austrian Sign Language for key procedures	C	–
F33	Accessibility	Large text and high-contrast mode	M	–
F34	Phone agent	Call ida inside the app and speak freely, without menus	M	–

ID	Area	Requirement	Prio	Level
F35	Phone agent	Say at the start of every call that ida is an AI; a person is available at any time	M	–
F36	Phone agent	Read back key values (dates, amounts, names) and ask for confirmation	M	B
F37	Phone agent	Critical actions during a call: face match on screen before submission	M	K
F38	Phone agent	Save a summary of the call and the next steps in the app	S	B
F39	Phone agent	Live transfer to staff during the call, with case summary	M	B

C. Non-functional requirements (full list)

ID	Quality	Requirement	Target / evidence
N01	Security	Strong login via ID Austria; face match before critical actions	No personal data without valid session
N02	Security	Encryption in transit and at rest	TLS 1.3, AES-256
N03	Security	Register access only server-side via Portal Network and dadeX	Architecture review
N04	Security	Least privilege: only the fields a procedure needs	Query log
N05	Security	Immutable log of all queries, submissions and admin access	Log audit
N06	Security	Penetration tests and protection against prompt injection in uploaded documents	Test reports, before each release
N07	Security	Session timeout; remote device lock	15 min inactivity
N08	Privacy	Consent per purpose, revocable at any time	Data cockpit
N09	Privacy	No copies of register data; uploads deleted after case closes	Deletion concept
N10	Privacy	Biometrics processed on device only; no face data stored	Data protection impact assessment

ID	Quality	Requirement	Target / evidence
N11	Privacy	Hosting in Austria / EU; inputs never used for model training	Contracts, hosting proof
N12	Compliance	GDPR, AI Act, AVG amendment, E-Government Act	Legal review
N13	AI reliability	Deadlines, fees and requirements only from the verified knowledge base	Test cases
N14	AI reliability	Translations use a verified legal glossary; German text is binding	Native-speaker tests
N15	AI reliability	When unsure: ask back or hand over, never guess	Test cases
N16	Accessibility	WCAG 2.1 AA mandatory, WCAG 2.2 AA target; screen-reader ready	Audit report
N17	Accessibility	Touch targets ≥ 44 px, contrast ≥ 4.5:1, text scalable to 200 %	Audit report
N18	Usability	Federal Government corporate design; plain language B1	User tests
N19	Usability	A typical application completed in under 10 minutes	Pilot measurement
N20	Performance	Chat answer < 3 s; letter explanation < 10 s	Monitoring
N21	Availability	99.9 % uptime, 24/7; announced maintenance windows	Monitoring
N22	Scalability	New procedure = new service description + workflow template, no new code	Effort per procedure
N23	Scalability	New language = verified glossary + tests, no new content	Effort per language
N24	Interoperability	Open interfaces to authority systems, appointment systems, ID Austria, later EUDI Wallet	Interface docs
N25	Maintainability	Language model replaceable without changing the knowledge base	Architecture review

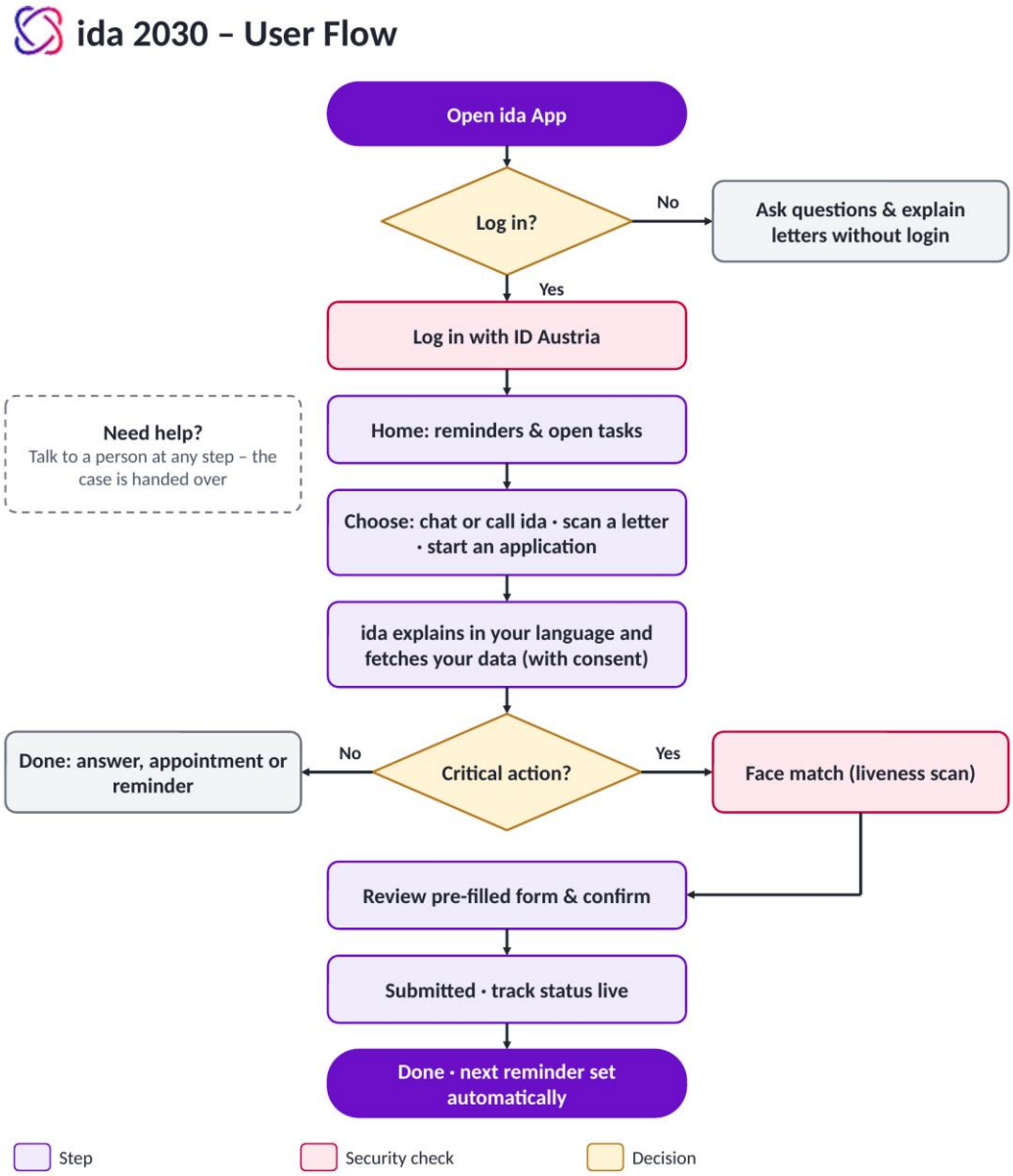
ID	Quality	Requirement	Target / evidence
N26	Transparency	Every AI answer labelled; sources visible	Spot checks
N27	Performance	Natural conversation without long pauses on the phone agent	Response < 1.5 s after the caller stops speaking
N28	Usability	Phone agent understands Austrian dialects, slow speech and background noise	Speech tests with older people and dialect speakers
N29	Privacy	Calls not recorded by default; transcript only with consent, deleted after the case closes	Deletion concept
N30	Availability	If speech fails, the call continues in chat or goes to the human hotline	Failover test

D. Threat model (full, incl. phone agent)

Threat	Example	Countermeasure
Spoofing	Someone logs in as another person	ID Austria + face match with liveness check
Tampering	Manipulated application data	Confirmation step, signed requests, immutable log
Repudiation	"I never submitted that"	Audit log with ID Austria confirmation
Information disclosure	Data leak from storage	No register copies, encryption, least privilege
Denial of service	Overload before a deadline	DDoS protection, rate limits, auto-scaling
Elevation of privilege	Prompt injection in an uploaded letter	Documents treated as data only; AI cannot trigger actions on its own
Information disclosure	Someone nearby overhears sensitive data during a call	ida asks before reading sensitive data aloud and offers to show it on screen
Elevation of privilege	A caller talks the agent into skipping a check ("it's urgent")	Rules are enforced in the backend; the AI cannot skip a step

E. General user flow

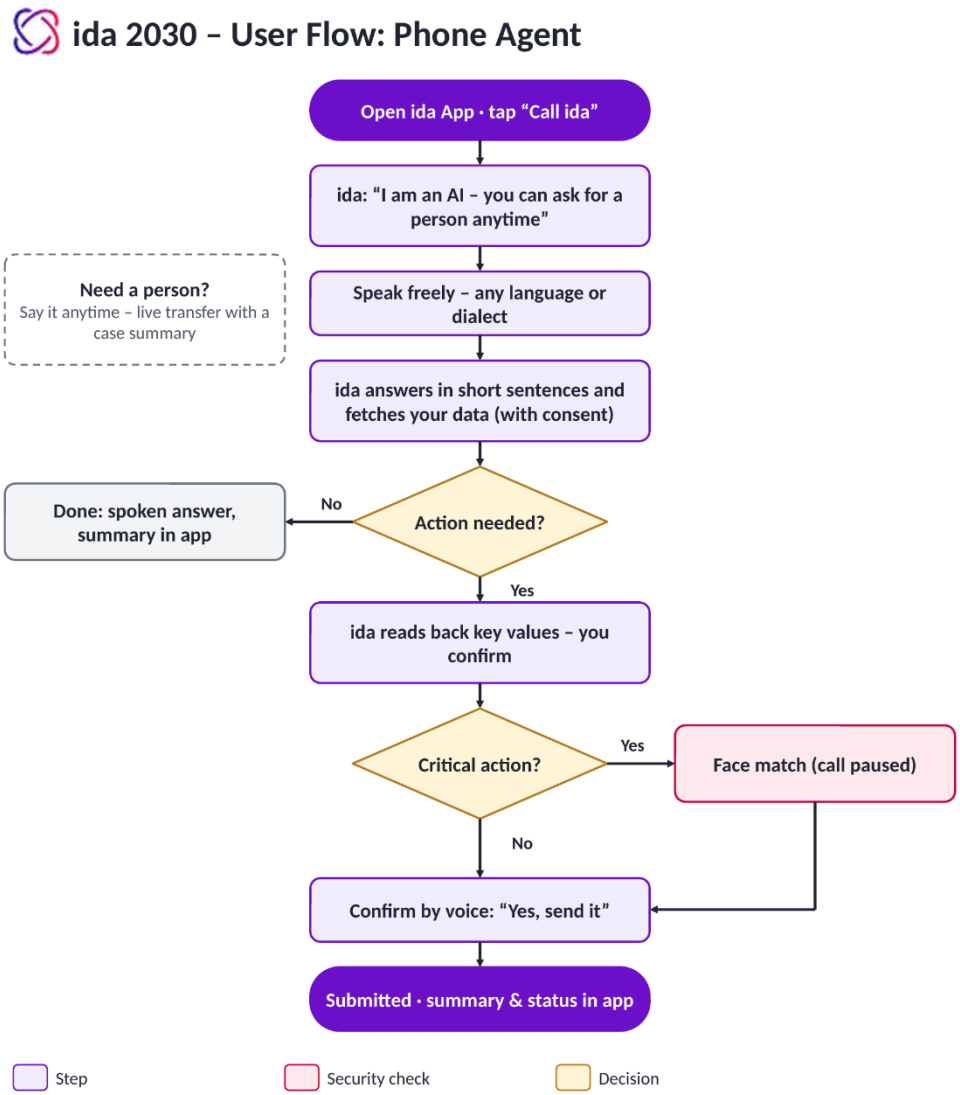
The flow is the same for every procedure: ida explains without login, everything personal needs ID Austria, and only critical actions add a face match. The resident can chat or call ida, and a person can take over at any step.



F. User flow: phone agent

Residents who prefer to talk can call ida directly in the app. Because they are already logged in with ID Austria, ida can access their data straight away – with consent, as in the chat. At the start of every call, ida says that it is an AI and that a person is available at any time. The caller speaks freely, in any language or dialect, and ida answers in short sentences, one step at a time.

Before any action, ida reads back the key values such as dates, names and amounts, and the caller confirms them. For a critical action, the call pauses and the face match runs on screen; the caller then confirms by voice and ida submits. A summary of the call and the application status are saved in the app. If the caller asks for a person, the call is transferred live to staff together with a case summary.



G. Glossary

Term	Meaning
CIA triad	Confidentiality, integrity, availability – the three goals of information security
dadeX	Digital Austria Data Exchange, the federal data hub between registers and authorities
PVP	Portal Network Protocol, how Austrian authorities authenticate to each other
Project X	Federal programme to connect registers via dadeX by 2029
Liveness check	Proof that a real person is in front of the camera, not a photo or video
Grounding (RAG)	The AI answers from retrieved verified documents instead of its own memory
Step-up authentication	A stronger identity check only for critical actions
Speech-to-text / text-to-speech	Turns spoken words into text and text back into speech
Read-back	ida repeats key values aloud so the caller can confirm them